

Content Security Policy (CSP) Header Not Set

Assessment Identifier: **WS-DYN-04** | Assessment Type: **Dynamic** | Date: **September 08, 2026**

Severity: MEDIUM	CVSS: 5.3	CWE: CWE-693
OWASP: A05:2021 - Security Misconfiguration	WASC ID: 15	Confidence: High
Target / Component: Edge / CDN Protection Gateway	Affected URL: https://www.worldmonito r.app/cdn-cgi//email-protection	Parameter: Header Missing: Content-Security-Policy

1. Description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

2. Steps to Reproduce

1. Send an HTTP GET request to https://www.worldmonitor.app/cdn-cgi//email-protection.
2. Inspect the HTTP response headers returned by the server.
3. Observe that no Content-Security-Policy header is present in the server's response.

3. Controlled Proof of Concept

```

HTTP/1.1 404 Not Found
Date: Tue, 08 Sep 2026 10:36:22 GMT
Content-Type: text/html
Connection: keep-alive
X-Frame-Options: DENY
X-Frame-Options: SAMEORIGIN
Cache-Control: private, max-age=0, no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Expires: Thu, 01 Jan 1970 00:00:01 GMT
Referrer-Policy: same-origin
(Notice: No Content-Security-Policy header returned)

```

4. Business & Security Impact

Without a Content Security Policy header defined on this route, the client browser lacks defense-in-depth restrictions against content injection. If an attacker identifies an XSS or HTML injection vulnerability on this endpoint, the browser will execute any injected scripts or load external malicious resources without restriction, potentially compromising user session data or leading to site defacement.

5. Remediation Recommendations

Primary Fix: Configure the edge proxy or web server to enforce CSP on all routes including error pages and utility paths.

1. Configure the web server, application framework, or edge proxy (e.g., Cloudflare/reverse proxy) to include a robust Content-Security-Policy header for all HTTP responses, including 404 and edge-generated endpoints.
2. Ensure the policy defines strict fallback directives (such as default-src 'self') and restricts untrusted origins for scripts, styles, and framed content.

6. Evidence & Validation

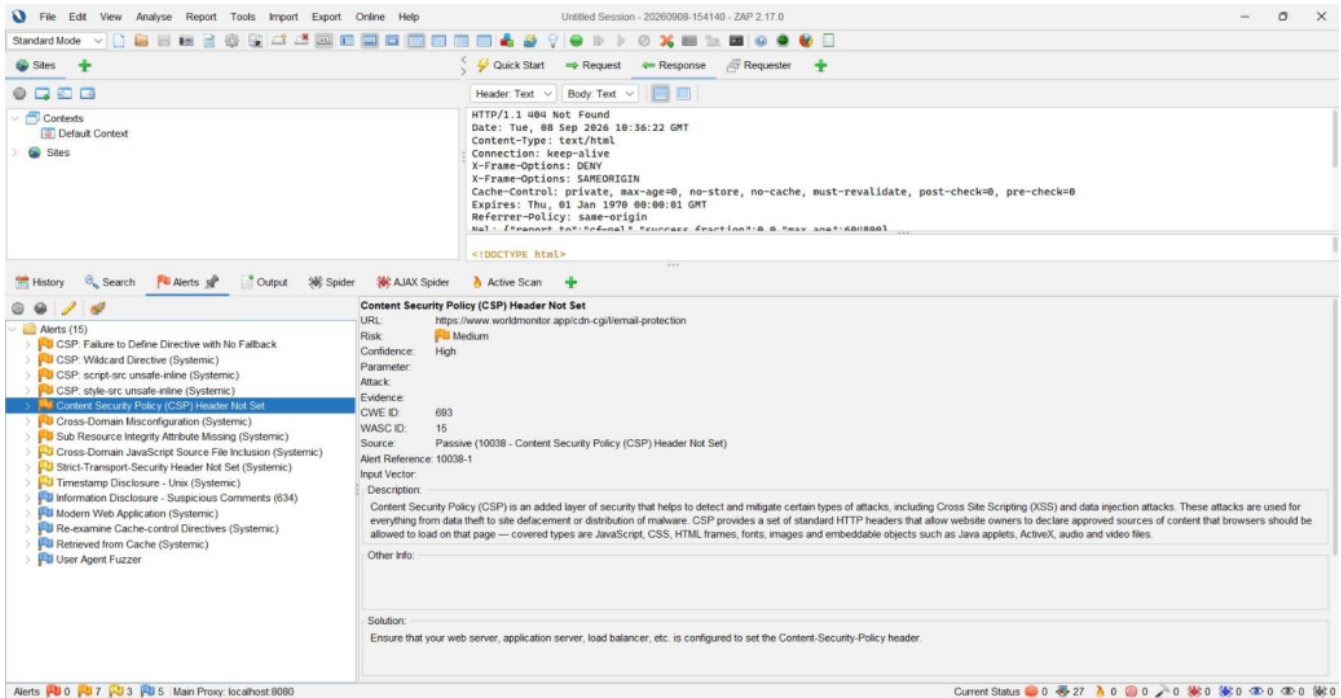


Figure 1: Matched Proof-of-Concept Screenshot for Vulnerability #4 (4/poc-1.png)

Authorization & Safety Compliance: This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.